

ADMINISTRATION LINUX

Grille d'audit Linux

Projet final · Audit d'un serveur Linux



Règles générales

- Statuts : conforme = 1; partiel = 0,5; non = 0.
- Score pondéré d'un domaine = somme des poids du domaine multipliés par la valeur du statut, divisée par la somme des poids du domaine, puis conversion en pourcentage entier avec 0,5 vers le haut.
- Score global = somme de tous les poids multipliés par la valeur du statut, divisée par la somme de tous les poids, puis conversion en pourcentage entier avec 0,5 vers le haut.
- Priorisation des actions : commence par les contrôles jugés partiels ou non conformes, calcule le risque avec vraisemblance × impact, puis trie par risque décroissant et effort croissant.
- Gain rapide : action liée à un contrôle jugé partiel ou non conforme, avec effort égal à 1 et risque au moins égal à 6.
- Niveaux de risque : faible de 1 à 3, moyen de 4 à 7, élevé de 8 à 11, critique de 12 à 16.
- Niveaux de maturité : a de 0 à 39, b de 40 à 59, c de 60 à 79, d de 80 à 100.

ID	DOMAINE	POIDS	STATUT	CRITÈRE D'ÉVALUATION
AC1	accès et comptes	3		Conforme si la valeur effective est no; partiel si elle est prohibit-password; non sinon.
AC2	accès et comptes	3		Conforme si PasswordAuthentication vaut no; partiel si la valeur vaut yes mais que l'accès SSH d'administration est limité à une source précise; non sinon.
AC3	accès et comptes	2		Conforme si aucun compte de service n'a de shell interactif; partiel si un seul compte de service en a un; non s'il y en a deux ou plus.
AC4	accès et comptes	2		Conforme si aucune règle sudo ne donne NOPASSWD ou un joker large à un compte non root; partiel s'il existe exactement une règle concernée; non s'il y en a deux ou plus.
RE1	réseau	2		Conforme si la politique par défaut en entrée est deny; partiel si elle est reject; non sinon.
RE2	réseau	3		Conforme si la règle SSH n'autorise qu'une source d'administration précise; partiel si un sous-réseau restreint est autorisé; non sinon.
RE3	réseau	2		Conforme si trois ports TCP ou moins écoutent sur toutes les interfaces (adresse locale 0.0.0.0); partiel si le total vaut quatre ou cinq; non au-delà.

ID	DOMAINE	POIDS	STATUT	CRITÈRE D'ÉVALUATION
RE4	réseau	1		Conforme si net.ipv4.ip_forward vaut 0 et si rp_filter vaut 1; partiel si une seule de ces deux conditions est respectée; non sinon.
SY1	système et correctifs	3		Conforme si aucun correctif de sécurité n'est en attente; partiel s'il y en a un ou deux; non s'il y en a trois ou plus.
SY2	système et correctifs	1		Conforme si l'occupation disque reste sous 85 % et les inodes sous 80 %; partiel si l'un des deux seuils est dépassé sans atteindre 95 %; non si l'un des deux atteint 95 % ou plus.
SY3	système et correctifs	2		Conforme si /tmp porte nodev, nosuid et noexec; partiel si exactement deux de ces options sont présentes; non sinon.
SY4	système et correctifs	2		Conforme si le support standard de la version du système n'est pas terminé à la date d'audit, d'après le calendrier de support fourni; partiel si le support standard est terminé mais que le support étendu reste actif; non sinon.
JO1	journalisation	2		Conforme si le service de journalisation local est actif; partiel s'il est relancé de façon intermittente; non sinon.
JO2	journalisation	1		Conforme si la rotation des journaux web est active avec conservation et compression; partiel si un seul de ces deux éléments manque; non sinon.
JO3	journalisation	3		Conforme si auditd est actif; partiel s'il est installé mais inactif; non s'il est absent ou en échec.
JO4	journalisation	2		Conforme si l'envoi vers le collecteur central est actif; partiel si la configuration existe mais reste désactivée; non si aucune trace de configuration n'existe.
SA1	sauvegardes	3		Conforme si la dernière sauvegarde réussie a moins de 24 heures; partiel si elle date de 24 à 72 heures; non au-delà.
SA2	sauvegardes	2		Conforme si la dernière copie hors site réussie a sept jours ou moins; partiel si elle date de huit à quatorze jours; non au-delà.
SA3	sauvegardes	2		Conforme si un test de restauration réussi date de 90 jours ou moins; partiel s'il date de 91 à 180 jours; non au-delà ou s'il est absent.
SA4	sauvegardes	2		Conforme si le dépôt chiffre les données et vérifie l'intégrité avec SHA-256 ou mieux; partiel si une seule de ces deux conditions est vraie; non sinon.
SE1	configuration des services	2		Conforme si MariaDB écoute uniquement sur 127.0.0.1 ou localhost; partiel si elle écoute sur une adresse interne seulement; non sinon.
SE2	configuration des services	3		Conforme si le dossier d'upload empêche l'exécution de PHP; partiel si la protection n'est présente que dans une seule couche (nginx ou PHP-FPM); non sinon.
SE3	configuration des services	1		Conforme si aucun service n'est en échec, auditd mis à part puisqu'il est déjà jugé par JO3; partiel s'il y en a exactement un; non s'il y en a deux ou plus.

ID	DOMAINE	POIDS	STATUT	CRITÈRE D'ÉVALUATION
SE4	configuration des services	2		Conforme si les scripts appelés par cron root appartiennent à root et ne sont pas modifiables par d'autres ; partiel si un seul script appelle un chemin indirect ; non sinon.

**Pingo veille sur ta progression**

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.